

- Filename: comptia-pentest-plus-pt0-002-1-1-1-regulation-and-compliance.md
- Show Name: Pentest+ (PT0-002)
- Topic Name: Planning and Scoping
- Episode Name: Regulation and Compliance

Regulation and Compliance

Objectives:

- Define Regulation and Compliance
- Describe how regulations and compliance can effect penetration testing
- Explore PCI-DSS and GDPR as examples of regulations and compliance

-
- What is regulation and compliance
 - Why do penetration testers need to concern themselves with it
 - Examples of relevant regulations
 - PCI-DSS (Payment Card Industry - Data Security Standard)
 - Meant to "increase controls around cardholder data to reduce credit card fraud"
 - Vulnerability Assessments and/or Penetration Tests vary in accordance to the size of the organization
 - Merchant Levels
 - Level 4: Less than 20k annual transactions
 - Self Assessment Questionnaire (SAQ)
 - Level 3: Between 20k and 1m annual transactions
 - SAQ
 - Quarterly network scan by Approved Scan Vendor(ASV)
 - Attestation of Compliance form
 - Level 2: Between 1m and 6m annual transactions
 - Compliance same as Level 3
 - Level 1: Over 6m annual transactions
 - Quarterly network scan by ASV
 - Attestation of Compliance
 - Annual Report on Compliance(ROC) by Qualified Security Assessor(QSA)
 - PCI-DSS Requirement 11 (p.96 of PCI-DSS v3-2-1)
 - More documents here
 - https://www.pcisecuritystandards.org/document_library?document=pci_dss
 - GDPR
 - <https://gdpr.eu/tag/gdpr/>
 - Article 32
 - A process for regularly testing, assessing and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing.
 - Article 35

- carry out an assessment of the impact of [planned] processing operations on the protection of personal data

https://www.pcisecuritystandards.org/documents/PCI_DSS_v3-2-1.pdf?agreement=true&time=1634047549619